

## FAICP: MARCO DE INDICADORES DE CIBERSEGURIDAD PARA SISTEMAS DE IA

### Tendencias 2025–2026 · Métricas Territoriales para España por CCAA · Perspectiva Comparativa Mundial

*"La inteligencia artificial ha cometido el imperdonable error de convertirse en infraestructura crítica antes de que tuviéramos la infraestructura normativa para protegerla. El FAICP es, en cierta medida, la disciplina que se impone a posteriori con la esperanza de que no sea demasiado tarde."*

**Tipo:** Informe de Investigación Integral | **Versión:** 1.0 — Abril 2026

**Ámbito:** Nacional (España) con perspectiva comparativa UE y global

**Marco de referencia principal:** NIST IR 8596 · AI RMF 1.0 · EU AI Act 2024/1689 · ENS · NIS2 · ISO/IEC 42001

### RESUMEN EJECUTIVO

El año 2025 marcó un punto de inflexión para la ciberseguridad de los sistemas de inteligencia artificial: el NIST publicó el borrador preliminar del **Cyber AI Profile (NIST IR 8596)**, el primer marco que traduce sistemáticamente las seis funciones del Cybersecurity Framework (CSF) 2.0 en indicadores específicos para entornos de IA. Simultáneamente, la Agencia Española de Supervisión de Inteligencia Artificial (AESIA) publicó 16 guías prácticas de cumplimiento del EU AI Act —las primeras de su tipo en Europa—, y el Gobierno de España aprobó la mayor inversión histórica en ciberseguridad: 1.157 millones de euros para el período 2025-2026.

Sin embargo, estos avances normativos y presupuestarios contrastan con una realidad de madurez operativa que este informe caracteriza como **transición crítica**: las organizaciones españolas muestran niveles de preparación heterogéneos, con brechas especialmente pronunciadas en detección de amenazas adversariales de IA y en capacidades de respuesta específica para incidentes de IA. El Cisco Cybersecurity Readiness Index 2025 sitúa a España con un 19% de empresas en nivel "Mature" —muy por encima de la media global del 4%—, pero solo el 7% ha alcanzado madurez en "AI Fortification", lo que refleja exactamente esa asimetría entre la postura de seguridad general y la específica para IA.

Este informe presenta: (1) el estado del arte del marco FAICP desde 2025, (2) los indicadores y métricas propuestos con aplicación territorial por CCAA, y (3) un análisis comparativo mundial que contextualiza el posicionamiento de España en el mapa de la ciberseguridad IA global.

### PARTE I — ESTADO DEL ARTE DEL FAICP (2025–2026)

#### 1.1. Génesis y Evolución del Marco

El término **FAICP (Framework for AI Cybersecurity Practices)** engloba el conjunto de marcos, guías y perfiles que articulan las prácticas de ciberseguridad específicas para sistemas de inteligencia artificial, con el **NIST IR 8596 Initial Public Draft (diciembre 2025)** como documento fundacional más reciente y de mayor relevancia institucional.

El Cyber AI Profile del NIST emerge de la necesidad de operacionalizar tres documentos previos:

- **NIST AI RMF 1.0 (enero 2023)**: Marco de gestión de riesgos para IA con foco en fiabilidad, pero sin articulación detallada de controles de ciberseguridad
- **NIST CSF 2.0 (febrero 2024)**: Actualización del Cybersecurity Framework con nueva función "Gobernar" pero sin especificidad para IA
- **NIST AI 100-1 (agosto 2023)**: Taxonomía de riesgos de IA generativa que identifica 12 categorías de riesgo específicas de LLM/GenAI

El IR 8596 sintetiza estos marcos en un perfil de ciberseguridad específico para IA organizado en torno a tres dimensiones de riesgo (**SECURE / DEFEND / THWART**) y seis funciones de gestión (Gobernar, Identificar, Proteger, Detectar, Responder, Recuperar), identificando indicadores de alta prioridad denominados **Tier 1** para cada función.

### 1.2. Los Indicadores Tier 1 del NIST IR 8596

El borrador del Cyber AI Profile identifica los siguientes **indicadores de alta prioridad**:

| Código NIST | Indicador                                                | Descripción Operativa                                                                                                    |
|-------------|----------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| GV.OC-04    | Política de uso de IA con aspectos de ciberseguridad     | Existencia de política formal que aborde riesgos de IA adversarial, uso de IA en operaciones, cadena de suministro de IA |
| GV.OC-05    | Dependencias de infraestructura crítica identificadas    | Mapa de dependencias de la organización en sistemas de IA externos y en la nube                                          |
| GV.RR-04    | Riesgos de IA adversarial en RRHH y formación            | Integración de amenazas de IA (deepfakes, phishing LLM, ingeniería social IA) en formación de personal                   |
| GV.SC-07    | Riesgos de ciberseguridad de proveedores de IA evaluados | Due diligence de seguridad para modelos de terceros, APIs de IA, proveedores de entrenamiento                            |
| ID.AM-07    | Inventario de sistemas de IA con datos entrenamiento     | AI-BOM: inventario completo incluyendo origen de datos, versiones de modelos, dependencias                               |
| PR.AA-01    | Gestión de identidades para sistemas de IA               | IAM específico para agentes de IA, APIs de modelos, consolas de gestión MLOps                                            |
| PR.AA-05    | Menor privilegio para sistemas de IA autónomos           | Restricción de scope de acción de agentes, sandboxing, límites de recursos                                               |
| DE.CM-06    | Monitorización de comunicaciones de IA                   | Supervisión de tráfico hacia/desde APIs de IA externas, logs de inferencia                                               |
| DE.CM-09    | Monitorización de ejecución de IA                        | Vigilancia en tiempo real de comportamiento de sistemas IA en producción                                                 |
| RS.MA-01    | Playbooks de respuesta a incidentes de IA                | Procedimientos específicos para escenarios de incidente con IA como vector o sistema comprometido                        |
| RC.RP-02    | Planes de recuperación para sistemas de IA               | Backups de modelos, procedimientos de rollback, validación de integridad post-recuperación                               |

### 1.3. El OWASP LLM Top 10 (2025) como Referente Técnico Complementario

El OWASP Top 10 para Large Language Model Applications, actualizado en noviembre de 2024 para el ciclo 2025, aporta la taxonomía de vulnerabilidades técnicas específicas de sistemas LLM que complementa los indicadores del Cyber AI Profile:

| Ranking | Vulnerabilidad                   | Descripción                                                                                         | Impacto                                                                                  |
|---------|----------------------------------|-----------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|
| LLM01   | Prompt Injection                 | Manipulación del comportamiento del modelo mediante instrucciones maliciosas insertadas en el input | Ejecución de acciones no autorizadas, exfiltración de información, evasión de guardrails |
| LLM02   | Sensitive Information Disclosure | Exposición de datos confidenciales en respuestas del modelo                                         | Fuga de PII, datos corporativos, secretos del system prompt                              |
| LLM03   | Supply Chain                     | Comprometimiento de la cadena de suministro del modelo (datos, pesos, dependencias)                 | Backdoors en modelos, modelos comprometidos en repositorios públicos                     |
| LLM04   | Data and Model Poisoning         | Manipulación de datos de entrenamiento o ajuste para sesgar el comportamiento                       | Decisiones sesgadas, backdoors funcionales, degradación de rendimiento                   |
| LLM05   | Improper Output Handling         | Tratamiento inadecuado de outputs del LLM en pipelines posteriores                                  | XSS, SSRF, ejecución de código mediante outputs no sanitizados                           |
| LLM06   | Excessive Agency                 | Exceso de capacidades de acción autónoma concedidas al sistema de IA                                | Acciones no intencionadas de alto impacto, escalada de privilegios automatizada          |
| LLM07   | System Prompt Leakage            | Exposición del prompt de sistema (instrucciones confidenciales)                                     | Revelación de arquitectura interna, bypasses de restricciones de seguridad               |
| LLM08   | Vector and Embedding Weaknesses  | Vulnerabilidades en sistemas RAG y bases de datos vectoriales                                       | Exfiltración de documentos almacenados, ataques de envenenamiento de índices             |
| LLM09   | Misinformation                   | Generación de información falsa con apariencia de veracidad                                         | Decisiones corporativas erróneas basadas en outputs del modelo                           |
| LLM10   | Unbounded Consumption            | Consumo descontrolado de recursos (tokens, API calls, procesamiento)                                | Denegación de servicio, costes operativos descontrolados, degradación del servicio       |

#### 1.4. MITRE ATLAS: El ATT&CK de la IA Adversarial

MITRE ATLAS (Adversarial Threat Landscape for Artificial-Intelligence Systems), en su actualización de octubre de 2025, documenta **15 tácticas, 66 técnicas y 43 subtécnicas** específicas de ataques a sistemas de IA. Las tácticas principales son:

| Táctica    | Descripción          | Técnicas representativas                                                  |
|------------|----------------------|---------------------------------------------------------------------------|
| AML.TA0000 | Reconnaissance       | Búsqueda de modelos objetivo en repositorios, análisis de APIs públicas   |
| AML.TA0001 | Resource Development | Creación de modelos de sustitución, infraestructura de ataque             |
| AML.TA0002 | Initial Access       | Compromiso de repositorios de modelos, acceso a sistemas de entrenamiento |
| AML.TA0004 | Execution            | Inyección de prompt, manipulación de pipeline ML                          |
| AML.TA0009 | Exfiltration         | Extracción del modelo (model stealing), ataques de inversión              |
| AML.TA0011 | Impact               | Envenenamiento de modelo en producción, degradación funcional             |

#### 1.5. ISO/IEC 42001:2023 — El Sistema de Gestión de IA

La norma ISO/IEC 42001:2023, primer estándar internacional de sistema de gestión para organizaciones que desarrollan u operan sistemas de IA, establece los requisitos para un **Artificial Intelligence Management System (AIMS)**. Su estructura de cláusulas 4-10 es completamente paralela a ISO 27001:2022, facilitando la integración con los SGSI existentes.

##### Aspectos diferenciadores para la ciberseguridad de IA:

- **Cláusula 6.1.2:** Evaluación de impacto del sistema de IA (integrando dimensiones de seguridad, privacidad y derechos fundamentales)
- **Anexo A.6:** Recursos de datos para sistemas de IA (integridad, calidad, procedencia)
- **Anexo A.8:** Operación del sistema de IA (incluyendo logging de inferencia, monitorización de rendimiento)
- **Anexo B.7:** Ciberseguridad específica para sistemas de IA (control B.7.4 sobre ataques adversariales)

## PARTE II — MÉTRICAS FAICP: OPERACIONALIZACIÓN Y MEDICIÓN

#### 2.1. El Índice de Gobernanza y Madurez FAICP (IGM-FAICP)

El **IGM-FAICP** es el indicador compuesto que sintetiza la postura de ciberseguridad IA de una organización en una puntuación 1-5. Su fórmula:

$$IGM = \sum_{f=1}^6 w_f \cdot \bar{M}_f$$

Donde  $w_f$  son los pesos por función (GV=0.20, ID=0.20, PR=0.25, DE=0.15, RS=0.10, RC=0.10) y  $\bar{M}_f$  la media de los indicadores de esa función.

## 2.2. Indicadores Específicos por Función — Taxonomía Completa

### Función GOBERNAR — 6 Indicadores

| Código    | Indicador                                             | Métrica                 | Umbral Recomendado              |
|-----------|-------------------------------------------------------|-------------------------|---------------------------------|
| IGM-GV-01 | Existencia y calidad de política de ciberseguridad IA | Escala 1-5 (Likert)     | ≥3 para sectores críticos       |
| IGM-GV-02 | Mapeo de dependencias de infraestructura IA           | Escala 1-5              | ≥3 para entidades NIS2          |
| IGM-GV-03 | Integración de amenazas IA en RRHH y formación        | Escala 1-5              | ≥3 para todas las entidades     |
| IGM-GV-04 | Evaluación de riesgos de proveedores IA               | Escala 1-5              | ≥4 para sistemas alto riesgo    |
| IGM-GV-05 | Función de gobernanza de IA (comité/responsable)      | Binario + calidad (1-5) | ≥3 para AAPP y grandes empresas |
| IGM-GV-06 | Cumplimiento EU AI Act: registro y clasificación      | Escala 1-5              | 5 para sistemas de alto riesgo  |

### Función IDENTIFICAR — 5 Indicadores

| Código    | Indicador                                                 | Métrica                          | Umbral Recomendado           |
|-----------|-----------------------------------------------------------|----------------------------------|------------------------------|
| IGM-ID-01 | Compleitud del AI-BOM / inventario de sistemas IA         | Escala 1-5                       | ≥3 para todas las entidades  |
| IGM-ID-02 | Evaluación de vulnerabilidades específicas de IA          | Escala 1-5 (taxonomía OWASP LLM) | ≥3 para entidades NIS2       |
| IGM-ID-03 | Consumo de inteligencia de amenazas adversariales IA      | Escala 1-5 (fuentes CTI)         | ≥3 para sectores críticos    |
| IGM-ID-04 | Modelado de velocidad de ataques IA en gestión de riesgos | Ordinal (4 niveles)              | Nivel ≥2 para todas          |
| IGM-ID-05 | Análisis de riesgos de cadena de suministro IA            | Escala 1-5                       | ≥4 para sistemas alto riesgo |

### *Función PROTEGER — 6 Indicadores*

| Código    | Indicador                                             | Métrica                | Umbral Recomendado            |
|-----------|-------------------------------------------------------|------------------------|-------------------------------|
| IGM-PR-01 | IAM específico para sistemas y agentes de IA          | Escala 1-5             | ≥3 para todas las entidades   |
| IGM-PR-02 | Principio de menor privilegio en agentes IA autónomos | Escala 1-5             | ≥4 para sistemas alta agencia |
| IGM-PR-03 | Cobertura y frecuencia de formación en amenazas IA    | Ordinal (5 niveles)    | Anual mínimo (nivel ≥3)       |
| IGM-PR-04 | Protección de datos de entrenamiento e inferencia     | Escala 1-5             | ≥4 para datos personales      |
| IGM-PR-05 | Control de versiones y gestión MLOps de modelos       | Escala 1-5             | ≥3 para producción            |
| IGM-PR-06 | Evaluación y control de riesgo de agencia excesiva    | Ordinal (5 categorías) | Nivel ≥3 para agentes         |

### *Función DETECTAR — 5 Indicadores*

| Código    | Indicador                                            | Métrica             | Umbral Recomendado                           |
|-----------|------------------------------------------------------|---------------------|----------------------------------------------|
| IGM-DE-01 | Monitorización de APIs de IA externas                | Escala 1-5          | ≥3 para entidades NIS2                       |
| IGM-DE-02 | Monitorización en tiempo de ejecución de sistemas IA | Escala 1-5          | ≥3 para IA crítica                           |
| IGM-DE-03 | Frecuencia y método de evaluación de model drift     | Ordinal (6 niveles) | Monitorización continua para alta criticidad |
| IGM-DE-04 | Capacidades del SOC para amenazas IA adversariales   | Escala 1-5          | ≥3 para operadores esenciales                |
| IGM-DE-05 | Controles de detección de prompt injection           | Escala 1-5          | ≥3 para sistemas LLM en producción           |

#### *Función RESPONDER — 4 Indicadores*

| Código    | Indicador                                              | Métrica                | Umbral Recomendado                     |
|-----------|--------------------------------------------------------|------------------------|----------------------------------------|
| IGM-RS-01 | Existencia y calidad de playbooks específicos de IA    | Escala 1-5             | ≥3 para operadores NIS2                |
| IGM-RS-02 | Capacidad de análisis forense de sistemas de IA        | Ordinal (5 categorías) | Categoría ≥2 para IA crítica           |
| IGM-RS-03 | Conocimiento y aplicación de plazos de notificación IA | Ordinal (5 categorías) | Categoría ≥3 para sistemas alto riesgo |
| IGM-RS-04 | MTTR-AI: Tiempo medio de respuesta a incidentes IA     | Temporal (7 rangos)    | ≤4 horas para sistemas críticos        |

#### *Función RECUPERAR — 3 Indicadores*

| Código    | Indicador                                           | Métrica                | Umbral Recomendado                           |
|-----------|-----------------------------------------------------|------------------------|----------------------------------------------|
| IGM-RC-01 | Planes de recuperación específicos para sistemas IA | Escala 1-5             | ≥3 para IA crítica                           |
| IGM-RC-02 | RTO-AI: Tiempo Objetivo de Recuperación para IA     | Temporal (6 rangos)    | ≤4 horas para sistemas críticos              |
| IGM-RC-03 | Revisión de decisiones del sistema comprometido     | Ordinal (5 categorías) | Categoría ≥2 para IA con impacto en personas |

### 2.3. Indicadores Sectoriales y de Cumplimiento

#### **Indicadores de cumplimiento normativo (Sección 8):**

| Código     | Marco     | Indicador                         | Métrica             |
|------------|-----------|-----------------------------------|---------------------|
| IGM-CUM-01 | EU AI Act | Estadio de implementación         | Ordinal (7 niveles) |
| IGM-CUM-02 | ENS       | Nivel de certificación            | Categorico          |
| IGM-CUM-03 | NIS2      | Estado de implementación Art. 21  | Ordinal (6 niveles) |
| IGM-CUM-04 | ISO 42001 | Adopción como marco de referencia | Ordinal             |
| IGM-CUM-05 | RGPD+AIA  | Realización de evaluaciones FRIA  | Ordinal             |

#### **Indicadores OT/ICS (Sección 7) — Para operadores con entornos industriales:**



| Código    | Indicador                                         | Métrica                |
|-----------|---------------------------------------------------|------------------------|
| IGM-OT-01 | Presencia de IA en sistemas de control industrial | Categorico (3 niveles) |
| IGM-OT-02 | Evaluación de riesgo OT-IA adversarial            | Escala 1-5             |
| IGM-OT-03 | Grado de segregación IT/OT                        | Ordinal (4 niveles)    |
| IGM-OT-04 | Ejercicios red team OT+IA                         | Ordinal (4 niveles)    |

## PARTE III — APLICACIÓN TERRITORIAL: MÉTRICAS POR CCAA

### 3.1. Marco de Análisis Territorial

La desagregación territorial por Comunidades Autónomas responde a una realidad estructural del sistema de ciberseguridad español: la coexistencia de capacidades de coordinación estatal (CCN-CERT, INCIBE) con responsabilidades autonómicas crecientes en materia de regulación de la IA, protección de datos y continuidad de servicios públicos. La transferencia del EU AI Act implica que AESIA coexiste con organismos autonómicos en la supervisión de sistemas de IA de las Administraciones Públicas regionales.

### 3.2. Dimensiones del Análisis Territorial

#### 3.2.1. Variables de Estratificación por CCAA

Para cada Comunidad Autónoma, los indicadores FAICP se calculan en las siguientes dimensiones:

| Dimensión                               | Variables                                                                           | Fuente de datos                        |
|-----------------------------------------|-------------------------------------------------------------------------------------|----------------------------------------|
| Ecosistema empresarial TIC              | Densidad de empresas TIC, inversión en digitalización, número de startups IA        | INE, Eurostat, ONTSI                   |
| Capacidades de la AAPP autonómica       | Nivel ENS de las AAPP autonómicas y locales, CCN-CERT: incidentes por región        | CCN-CERT, INCIBE informes anuales      |
| Presencia de operadores críticos        | Nº de operadores esenciales/importantes NIS2 con sede en la CCAA                    | CNPIC, INCIBE                          |
| Ecosistema formativo y de investigación | Universidades con grados en ciberseguridad/IA, centros de I+D, CERTs autonómicos    | RUCT, ENISA national ecosystem reports |
| Marco normativo autonómico de IA        | Estrategias autonómicas de IA, planes de digitalización con componente de seguridad | Portales de Gobierno de cada CCAA      |

#### 3.2.2. Índice Compuesto de Contexto Territorial (ICCT)

Para enriquecer el análisis del IGM-FAICP con el contexto donde opera cada organización, se propone un **Índice de Contexto Territorial** de cinco subcomponentes:

$$[ \text{ICCT}_{\{CCAA\}} = 0.25 \cdot E_{\{TIC\}} + 0.25 \cdot C_{\{AAPP\}} + 0.20 \cdot O_{\{criticos\}} + 0.15 \cdot F_{\{investigacion\}} + 0.15 \cdot N_{\{normativo\}} ]$$

Donde:

- $E_{\{TIC\}}$  = Ecosistema TIC (densidad y calidad del tejido empresarial tecnológico)
- $C_{\{AAPP\}}$  = Capacidad de las Administraciones Públicas (ENS, incidentes gestionados)
- $O_{\{criticos\}}$  = Presencia de operadores críticos (peso relativo en la economía autonómica)
- $F_{\{investigacion\}}$  = Formación e investigación en ciberseguridad/IA
- $N_{\{normativo\}}$  = Madurez del marco normativo autonómico de IA

### 3.2.3. Perfiles Territoriales Esperados

Basándose en datos disponibles de INCIBE, CCN-CERT y Cisco CRI 2025, se identifican los siguientes **arquetipos territoriales**:

| Arquetipo                    | CCAA Representativas            | Perfil Esperado         | Factores Diferenciadores                                                                      |
|------------------------------|---------------------------------|-------------------------|-----------------------------------------------------------------------------------------------|
| <b>Maduro-Concentrado</b>    | Madrid, País Vasco              | IGM estimado $\geq 3.5$ | Alta concentración de grandes empresas tech/finanzas/industria + ecosistema formativo potente |
| <b>Maduro-Industrial</b>     | Cataluña, Navarra               | IGM estimado 3.0–3.5    | Fuerte base industrial con adopción creciente de IA en OT + clústeres tecnológicos            |
| <b>Emergente-Dinámico</b>    | C. Valenciana, Aragón           | IGM estimado 2.5–3.0    | Digitalización acelerada pero madurez de seguridad aún en consolidación                       |
| <b>AAPP-Centrado</b>         | Castilla y León, Andalucía      | IGM estimado 2.5–3.0    | Foco en AAPP (sede INCIBE en León), sanidad pública, educación como sectores principales      |
| <b>Transición-Asimétrica</b> | Canarias, Extremadura, La Rioja | IGM estimado 2.0–2.5    | Asimetría entre AAPP bien coordinadas y tejido empresarial en transición digital              |

### 3.3. Métricas de Brechas Prioritarias por CCAA

Las brechas más significativas que se esperan identificar en el análisis territorial son:

**Brecha 1 — Gobernanza IA en AAPP Locales:** Los ayuntamientos de todas las CCAA muestran déficits estructurales en la adopción de marcos de gobernanza IA. El ENS como punto de referencia nacional tiene una adopción desigual: mientras las CCAA con mayor presupuesto digital (Madrid, País Vasco, Cataluña) alcanzan niveles de certificación altos, las CCAA con mayor proporción de AAPP locales pequeñas presentan brechas de hasta 1.5 puntos en el sub-índice Gobernar.

**Brecha 2 — AI-BOM en Industria OT:** Las CCAA con mayor concentración industrial (País Vasco, Navarra, Cataluña) enfrentan el desafío específico de inventariar los componentes de IA integrados en sistemas SCADA y DCS, una tarea para la que ni el ENS ni el propio EU AI Act ofrecen guía suficientemente detallada.

**Brecha 3 — Capacidades de Detección en PYME:** Las CCAA con mayor proporción de PYME en el tejido empresarial (La Rioja, Extremadura, Castilla-La Mancha) presentan déficits pronunciados en los indicadores de Detección, especialmente en monitorización de model drift y capacidades del SOC para amenazas IA.

**Brecha 4 — Cumplimiento EU AI Act en Sectores Emergentes:** La adopción de IA en sectores como agricultura de precisión (Extremadura, Castilla-La Mancha, Andalucía), turismo inteligente (Canarias, Baleares) y logística avanzada (C. Valenciana) está superando la capacidad de cumplimiento normativo de las empresas implicadas, especialmente en la clasificación de sistemas de alto riesgo.

### 3.4. Iniciativas Territoriales de Referencia

| CCAA            | Iniciativa                                 | Marco           | Relevancia para FAICP                                                      |
|-----------------|--------------------------------------------|-----------------|----------------------------------------------------------------------------|
| Castilla y León | INCIBE — Centro de Ciberseguridad Nacional | NIST, ENS       | Hub de formación y respuesta a incidentes; referente para toda la red CCAA |
| Madrid          | Madrid Digital 2027 + CIBER Madrid         | EU AI Act, ENS  | Estrategia de digitalización segura de la AAPP madrileña con componente IA |
| País Vasco      | Basque Cybersecurity Centre (BCSC)         | NIS2, ENS, NIST | CERT autonómico con capacidades OT/ICS; referente industrial europeo       |
| Cataluña        | CESICAT + Estratègia d'IA de Catalunya     | EU AI Act       | Agencia propia de ciberseguridad + hoja de ruta IA pública                 |
| Andalucía       | Agencia Digital de Andalucía               | ENS             | Coordinación de seguridad en AAPP autonómicas y locales                    |
| C. Valenciana   | IVASPE + Estrategia Valenciana IA          | NIS2, ENS       | Integración seguridad-IA en servicios públicos digitales                   |

## PARTE IV — PERSPECTIVA COMPARATIVA MUNDIAL

### 4.1. Principales Índices de Referencia (2025-2026)

#### 4.1.1. Cisco Cybersecurity Readiness Index 2025

El Cisco CRI 2025, basado en encuestas a 8.000 responsables de seguridad en 30 países, categoriza la preparación en cinco "pilares", siendo **AI Fortification** el más relevante para FAICP.

**Posicionamiento de España vs. global:**

| Pilar                   | España Mature (%) | Global Mature (%) | Gap (puntos) |
|-------------------------|-------------------|-------------------|--------------|
| Identity Intelligence   | 3%                | 6%                | -3           |
| Network Resilience      | 21%               | 7%                | +14          |
| Machine Trustworthiness | 12%               | 6%                | +6           |
| Cloud Reinforcement     | 19%               | 4%                | +15          |
| AI Fortification        | 7%                | 7%                | 0            |
| Global Mature           | 19%               | 4%                | +15          |

El dato más relevante es la **paridad en AI Fortification** (7% España = 7% global), que contrasta con el claro liderazgo en otros pilares. España es más madura en ciberseguridad general pero está exactamente en la media mundial en la dimensión específica de IA.

#### 4.1.2. WEF Global Cybersecurity Outlook 2025

El Informe del Foro Económico Mundial 2025 identifica la **brecha de capacidades de ciberseguridad** como el riesgo más crítico, con especial énfasis en la IA adversarial:

- 87% de los expertos del WEF prevén que la IA generativa incrementará los ataques en los próximos 2 años
- Solo 37% de las organizaciones dispone de procesos de evaluación de seguridad antes de desplegar nuevos sistemas de IA
- 72% de los CISOs considera que el ritmo de adopción de IA supera la capacidad de los equipos de seguridad para evaluarla
- El informe identifica a la cadena de suministro de IA como el vector de riesgo emergente de mayor prioridad

#### 4.1.3. ENISA Threat Landscape 2025 — Vectores de Amenaza IA

ENISA documenta en su ETL 2025 la evolución del rol de la IA en el panorama de amenazas:

**IA como herramienta de ataque:**

- El **80% de los ataques de ingeniería social** en la UE incorporaba componentes de IA generativa en 2024-2025
- Los **ataques de phishing con LLM** muestran tasas de éxito entre un 40% y un 65% superiores a los

ataques convencionales

- Los **deepfakes de voz** se usaron en fraudes de "CEO fraud" en al menos 15 incidentes significativos documentados en la UE
- El número de incidentes de **ransomware con evasión potenciada por ML** creció un 34% respecto al período anterior

#### IA como objetivo de ataque:

- Primeros casos documentados de **envenenamiento de modelos de IA en producción** en sectores críticos europeos
- Exfiltración de datos corporativos a través de herramientas de **GenAI Shadow IT**: en al menos 30% de organizaciones auditadas, empleados enviaban datos confidenciales a herramientas de IA sin autorización

#### 4.1.4. ENISA NIS Investment Report 2025

El informe de inversión en seguridad de ENISA para entidades NIS (2025) ofrece el benchmark financiero de referencia:

| Métrica                                   | Operadores Esenciales UE | Entidades Importantes UE | España (estimado) |
|-------------------------------------------|--------------------------|--------------------------|-------------------|
| % presupuesto TIC en seguridad            | 9.5%                     | 7.2%                     | ~8.5%             |
| % organizaciones con CISO                 | 84%                      | 67%                      | ~72%              |
| % con política de seguridad IA específica | 31%                      | 19%                      | ~25%              |
| % con formación específica en amenazas IA | 42%                      | 28%                      | ~35%              |

#### 4.2. Comparativa de Marcos Nacionales de Supervisión IA

| País               | Autoridad           | Marco de supervisión IA                                                           | Nivel de madurez regulatoria                   |
|--------------------|---------------------|-----------------------------------------------------------------------------------|------------------------------------------------|
| <b>España</b>      | AESIA (creada 2024) | EU AI Act + 16 Guías Prácticas (dic. 2025) + sandbox activo                       | Avanzado — líder en implementación EU AI Act   |
| <b>Alemania</b>    | BSI + BMAS          | EU AI Act + BSI AI Security Profile                                               | Avanzado — fuerte en sector industrial         |
| <b>Francia</b>     | ANSSI + CNIL        | EU AI Act + ANSSI recommendations IA                                              | Avanzado — referente en IA soberana            |
| <b>Italia</b>      | ACN + AGID          | EU AI Act + Piano Nazionale per l'IA 2024-2026                                    | Desarrollado — aceleración post-2023           |
| <b>Reino Unido</b> | NCSC + ICO          | UK AI Security Guidance (NCSC 2025) — enfoque basado en principios, no reglamento | Avanzado — diferenciado post-Brexit            |
| <b>EE.UU.</b>      | NIST + CISA         | NIST AI RMF + IR 8596 + Executive Order on AI Safety 2025                         | Avanzado — mayor profundidad técnica           |
| <b>Singapur</b>    | CSA                 | AI Governance Framework + AI Security Testing Guidelines                          | Avanzado — referente Asia-Pacífico             |
| <b>Japón</b>       | NISC + MIC          | AI Safety Guidelines (2025)                                                       | Desarrollado — aceleración reciente            |
| <b>China</b>       | CAC + MIIT          | Algorithmic Recommendation Regulation + Generative AI Regulation                  | Avanzado-diferente — modelo regulatorio propio |

#### 4.3. Vectores de Amenaza Emergentes: Lo que Viene

Los indicadores prospectivos de los principales centros de inteligencia de amenazas identifican los siguientes vectores emergentes para 2026-2027:

**1. Ataques adversariales a IA multimodal:** La proliferación de modelos que procesan texto, imagen, audio y vídeo simultáneamente amplía la superficie de ataque. Los ataques adversariales de "imagen envenenada" que manipulan la interpretación del modelo ya se documentan en contextos de visión por computador en procesos de control de calidad industrial.

**2. Explotación de agentes de IA autónomos con acceso a herramientas:** La adopción de frameworks de agentes (LangChain, AutoGen, CrewAI) con acceso a herramientas reales (navegadores, terminales, APIs empresariales) crea un nuevo perímetro de ataque: la **inyección de prompt indirecta**

**en documentos y páginas web** que el agente consulta, causando acciones no autorizadas sin interacción humana directa.

**3. Ataques a modelos de IA en el edge/IoT:** Con la proliferación de modelos pequeños (SLM) en dispositivos edge —cámaras, sensores industriales, dispositivos médicos—, los ataques físicos y de canal lateral para extraer pesos del modelo se convierten en un vector relevante para sectores de infraestructuras críticas.

**4. Envenenamiento de modelos de código abierto en repositorios públicos:** Hugging Face, GitHub y repositorios similares alojan miles de modelos sin verificación exhaustiva de seguridad. Los ataques de supply chain mediante backdoors en modelos populares ya cuentan con PoC (proof of concept) documentados.

**5. Uso de IA generativa para operaciones de influencia a escala organizacional:** Más allá del phishing individual, emergen escenarios de manipulación de decisiones corporativas mediante desinformación generada con IA dirigida a personas clave, en el contexto de espionaje industrial o ciberguerra económica.

## **PARTE V — POSICIONAMIENTO DE ESPAÑA: ANÁLISIS Y RECOMENDACIONES**

### **5.1. Fortalezas del Ecosistema Español de Ciberseguridad IA**

- Liderazgo en implementación EU AI Act: AESIA es la autoridad de supervisión IA más activa de Europa en 2025-2026, con 16 guías prácticas —las primeras de su tipo en la UE—, sandbox regulatorio operativo y un equipo técnico en rápida expansión
- Red de CERTs autonómicos: El modelo descentralizado español (CCN-CERT + INCIBE + CERTs autonómicos como BCSC, CESICAT, CITA) crea redundancia de capacidades y proximidad territorial
- INCIBE como hub formativo nacional: El ecosistema del INCIBE en León —con la sede del futuro Centro Nacional de Ciberseguridad— es una ventaja competitiva singular
- Preparación corporativa superior a la media global: El 19% de empresas en nivel "Mature" del Cisco CRI vs. 4% global es un indicador robusto de la calidad del tejido corporativo de seguridad

### **5.2. Brechas Identificadas**

- AI Fortification en paridad con la media global, no en liderazgo: El 7% de empresas con madurez en seguridad específica para IA iguala la media global pero no está a la altura de la posición de liderazgo general de España en ciberseguridad
- Brecha de talento especializado en ciberseguridad IA: La demanda de profesionales con conocimiento simultáneo de seguridad y sistemas de IA supera ampliamente la oferta, con un déficit estimado de 10.000-15.000 profesionales para 2027
- Asimetría territorial pronunciada: La concentración de capacidades en Madrid, País Vasco y Cataluña contrasta con déficits marcados en CCAA con menor ecosistema tecnológico
- Lentitud en adopción de AI-BOM: El inventario detallado de sistemas de IA (AI-BOM) es inexistente en la mayoría de organizaciones medianas y pequeñas, creando una ceguera estructural sobre la propia superficie de ataque



### 5.3. Recomendaciones por Nivel de Actuación

#### *Para el Regulador (AESIA, CCN, INCIBE)*

- Desarrollar un benchmark anual de madurez FAICP por CCAA y sector, publicado como dato abierto
- Crear perfiles de cumplimiento simplificados del EU AI Act para PYME y AAPP locales, alineados con los indicadores IGM-FAICP
- Establecer requisitos mínimos de AI-BOM en los pliegos de contratación pública para sistemas de IA
- Ampliar el sandbox regulatorio de AESIA con casos de uso específicos de ciberseguridad IA

#### *Para Operadores Esenciales e Importantes (NIS2)*

- Completar el AI-BOM como primer paso urgente, integrándolo en el inventario de activos del SGSI
- Desarrollar playbooks de respuesta para los cinco escenarios de mayor probabilidad: phishing LLM, deepfake fraude, prompt injection en sistemas internos, model drift no detectado, exfiltración vía Shadow AI
- Incorporar indicadores IGM-FAICP en el cuadro de mando del CISO para seguimiento trimestral
- Extender el programa de formación en amenazas IA a la totalidad del personal, no solo al equipo técnico

#### *Para la AAPP (Autonómica y Local)*

- Priorizar la certificación ENS + ISO 42001 como doble marco de referencia integrado para sistemas de IA en servicios públicos
- Establecer CISOs autonómicos con mandato explícito en ciberseguridad IA, coordinados con AESIA y CCN
- Adoptar el FAICP como criterio de evaluación en los procesos de adquisición de sistemas de IA para la AAPP

#### *Para el Ecosistema de Investigación y Formación*

- Crear titulaciones de especialización en ciberseguridad de sistemas IA en universidades con grados en Ingeniería Informática y Ciberseguridad
- Establecer un observatorio nacional de métricas FAICP con publicación semestral de datos agregados
- Promover la participación en ENISA AI Security Working Group y el grupo de desarrollo del NIST AI RMF

## EPÍLOGO: LA PARADOJA DEL INSTRUMENTO

Hay algo filosóficamente incómodo en medir la ciberseguridad de la inteligencia artificial con las mismas herramientas que la propia inteligencia artificial ha hecho obsoletas. Los frameworks de madurez, las escalas Likert, los índices compuestos: toda esta arquitectura métrica fue diseñada para un mundo donde las amenazas se movían a velocidad humana y los controles podían implementarse con tiempo de reflexión.

El **FAICP**, en sus múltiples expresiones normativas (IR 8596, AI RMF, EU AI Act, ISO 42001), tiene el mérito de reconocer esta asimetría y articular una respuesta estructurada. Pero reconocer el problema



es solo el primer paso. La velocidad a la que los sistemas de IA evolucionan —y con ellos sus superficies de ataque y sus vectores de amenaza— exige que estos marcos sean instrumentos vivos, actualizados con la misma cadencia con que el conocimiento técnico avanza.

España tiene, en este momento, una ventana de oportunidad singular: una autoridad regulatoria activa (AESIA), una red de capacidades públicas sólida (CCN-CERT, INCIBE, CERTs autonómicos), y un nivel de preparación corporativa superior a la media global. La pregunta no es si tiene los instrumentos, sino si tiene la voluntad colectiva de usarlos con la urgencia que el momento requiere.

El mapa que este informe pretende contribuir a construir no es la respuesta. Es la precondition para formular las preguntas correctas.

*Este informe es un documento de investigación de libre distribución con atribución.*

*Versión 1.0 — Abril 2026*

*Marcos de referencia: NIST IR 8596, NIST AI RMF 1.0, EU AI Act 2024/1689, ENS RD 311/2022, NIS2 2022/2555, ISO/IEC 42001:2023, OWASP LLM Top 10 2025, MITRE ATLAS Oct. 2025, Cisco CRI 2025, WEF GCO 2025, ENISA ETL 2025, ENISA NIS Investment Report 2025*